

SaaS Multitenant — Documentação de Regras de Negócio

Sistema de gestão comercial para pequenas empresas, com isolamento completo de dados entre clientes (multi tenant).

1. Visão geral

O sistema permite que múltiplas empresas usem a mesma aplicação de forma totalmente isolada: cada empresa só enxerga seus próprios clientes, produtos e vendas, mesmo compartilhando a mesma infraestrutura e o mesmo banco de dados.

O acesso é feito tanto por uma API REST (autenticação por token) quanto por uma interface web (autenticação por sessão), ambas seguindo exatamente as mesmas regras de negócio.

2. Entidades principais

Entidade	Descrição	Pertence a
Company	Empresa cliente do sistema (o tenant)	-
User	Usuário do sistema; papel owner, admin ou employee	Company
Customer	Cliente cadastrado pela empresa	Company
Product	Produto ou serviço vendido pela empresa	Company
Sale	Venda registrada, com status e total	Company, Customer, User
SaleItem	Item de linha de uma venda	Sale, Product

3. Regras de negócio

3.1 Isolamento entre empresas

- Todo dado de Customer, Product e Sale pertence a exatamente uma Company.
- Um usuário nunca pode ler, editar ou excluir um registro de outra empresa — mesmo manipulando IDs diretamente na URL ou na API.
- A empresa do usuário autenticado é a única fonte confiável para filtrar dados; nunca se aceita um `company_id` vindo do cliente (request).

3.2 Papéis de usuário

- owner — criado automaticamente no cadastro da empresa; acesso completo.

- admin — acesso amplo às operações do dia a dia.
- employee — papel padrão para novos convites (quando aplicável).

3.3 Vendas

- Uma venda (Sale) tem um ou mais itens (SaleItem), cada um referenciando um Product e uma quantidade.
- O valor total da venda é calculado automaticamente a partir da soma dos itens no momento do registro.
- O preço unitário é congelado no item da venda no momento da criação — alterações futuras no preço do produto não afetam vendas já registradas.
- Status possíveis: pending, completed, cancelled.
- Vendas pendentes há mais de 7 dias são canceladas automaticamente por uma rotina agendada

(scheduler). 4. Fluxos principais

4.1 Cadastro de uma nova empresa

1. O usuário se cadastra informando nome da empresa, nome pessoal, e-mail e senha.
2. O sistema cria a Company e o User como owner, na mesma transação.
3. O usuário já entra autenticado, pronto para cadastrar clientes e produtos.

4.2 Registro de uma venda

1. O usuário seleciona um cliente já cadastrado.
2. Adiciona um ou mais produtos, com a quantidade de cada um.
3. O sistema busca o preço atual de cada produto e calcula os subtotais.
4. A venda é registrada com status pending e o total calculado.
5. Um evento é disparado internamente, permitindo ações futuras (ex.: notificação, atualização de estoque).

5. Arquitetura (visão simplificada)

O isolamento entre empresas é resolvido por um Global Scope aplicado automaticamente a todo model sensível (Customer, Product, Sale), através de uma trait compartilhada. Isso garante que a filtragem por empresa aconteça em toda consulta, sem depender de lembrar de escrever a condição manualmente em cada lugar do código.

Representação textual do fluxo de uma requisição autenticada:

- Requisição chega (via API com token, ou via tela com sessão)
- Middleware identifica o usuário autenticado e sua empresa
- Controller executa a operação normalmente, sem se preocupar com isolamento
- Global Scope filtra automaticamente qualquer consulta ao banco pela empresa do usuário
- Resposta é retornada — nunca contendo dado de outra empresa

6. Segurança e autenticação

- Autenticação de API via Sanctum (token pessoal).
- Autenticação de tela via sessão, com autenticação em duas etapas (2FA) opcional via

aplicativo autenticador.

- Rate limiting aplicado nas rotas autenticadas, para conter abuso de requisições.